

NIS2 COMPLIANCE CHECKLIST

23 essential controls · applies to essential and important entities · based on NIS2 Articles 20, 21 & 23 and Poland's KSC Act

#	Control	Essential	Important	In place?
A. Governance & Registration				
1	Entity classification (essential vs. important) determined and documented, with the reasoning and data behind it	YES	YES	☐
2	Registered with the national authority (Poland: KSC Act - deadline October 3, 2026)	YES	YES	☐
3	Management board has formally approved the cybersecurity risk-management framework and oversees it (personal liability applies)	YES	YES	☐
4	Management has completed cybersecurity training; a staff awareness program is running	YES	YES	☐
5	Cybersecurity roles, responsibilities, and authority contact points are assigned and documented	YES	YES	☐
B. Risk-Management Measures (Art. 21)				
6	Risk analysis performed; information-system security policies adopted	YES	YES	☐
7	Incident-handling procedure covers detection, analysis, containment, response, and recovery	YES	YES	☐
8	Backup management in place; disaster recovery tested, not just documented	YES	YES	☐
9	Business continuity and crisis-management plan in place	YES	YES	☐
10	Supply-chain security: direct suppliers and service providers assessed for security posture	YES	YES	☐
11	Security requirements embedded in acquisition, development, and maintenance of systems	YES	YES	☐
12	Vulnerability handling and coordinated disclosure process in place	YES	YES	☐
13	Policies and procedures to assess the effectiveness of the measures themselves	YES	YES	☐
14	Basic cyber hygiene: patching, hardening, least privilege, network segmentation	YES	YES	☐
15	Cryptography policy: encryption at rest and in transit where appropriate	YES	YES	☐
16	Human-resources security, access control, and asset-management policies	YES	YES	☐
17	Multi-factor or continuous authentication deployed for critical access	YES	YES	☐
18	Secured voice, video, and text communications; emergency communication channels defined	YES	YES	☐
C. Incident Reporting (Art. 23)				
19	24-hour early-warning workflow to the CSIRT / competent authority	YES	YES	☐
20	72-hour full incident notification with initial severity and impact assessment	YES	YES	☐
21	Final report process delivering within one month of the incident notification	YES	YES	☐
D. Ongoing Compliance				
22	Audit readiness: evidence register maintained and current (Poland: risk measures due April 2027; first mandatory audits April 2028)	YES	YES	☐
23	Periodic validation: penetration tests, tabletop exercises, and control reviews on a schedule	YES	YES	☐

How the tiers differ: the controls are the same for both. Essential entities face proactive supervision and fines up to EUR 10M or 2% of global turnover; important entities face ex-post supervision and fines up to EUR 7M or 1.4%. Management can be held personally liable in both tiers.

Scored mostly "No" in any section? That is what a gap assessment is for. **Tenny Vongtip - NIS2 Compliance Auditor & Zero Trust Architect · GIAC-certified (8 domains) · tennylv.com · tenny.vongtip@gmail.com**